

Fundamentals of Information Systems Security

Practice Test 1

Comprehensive Examination Covering All Chapters

Name: _____

Date: _____

Total Points: 150

Time Allowed: 90 Minutes

Instructions

- This practice test contains **50 questions** covering all 9 chapters
- Answer all questions to the best of your ability
- Multiple choice questions have only one correct answer
- True/False questions should be marked T or F
- Short answer questions require concise, accurate responses
- You may use the answer sheet at the end to record your answers

Section A: Multiple Choice (60 points)

1. (2 points) Which of the following best defines information security?
 - A. Protecting only network infrastructure
 - B. Protection of information and its critical elements, including systems and hardware
 - C. Ensuring only employees have access to data
 - D. Installing antivirus software on all computers
2. (2 points) What does the “A” in the CIA Triad stand for?
 - A. Authorization
 - B. Authentication
 - C. Availability
 - D. Accountability
3. (2 points) Which of the following is NOT one of the seven IT infrastructure domains?
 - A. User Domain
 - B. LAN Domain
 - C. Management Domain
 - D. WAN Domain
4. (2 points) Who first coined the term “Internet of Things” in 1999?

- A. Bill Gates
 - B. Kevin Ashton
 - C. Tim Berners-Lee
 - D. Steve Jobs
5. (2 points) What is the primary purpose of a security policy?
- A. To generate revenue
 - B. To reduce risk and guide security decisions
 - C. To limit employee access to the internet
 - D. To comply with international law
6. (2 points) In the risk equation, $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times ?$
- A. Asset Value
 - B. Impact
 - C. Likelihood
 - D. Control
7. (2 points) Which type of risk assessment uses relative scales like High, Medium, and Low?
- A. Quantitative risk assessment
 - B. Qualitative risk assessment
 - C. Hybrid risk assessment
 - D. Technical risk assessment
8. (2 points) What is the correct formula for Single Loss Expectancy (SLE)?
- A. $\text{SLE} = \text{AV} \times \text{EF}$
 - B. $\text{SLE} = \text{AV} / \text{EF}$
 - C. $\text{SLE} = \text{AV} + \text{EF}$
 - D. $\text{SLE} = \text{ARO} \times \text{EF}$
9. (2 points) Which of the following is a function of the Business Impact Analysis (BIA)?
- A. Developing security policies
 - B. Identifying critical business functions and their recovery requirements
 - C. Conducting penetration tests
 - D. Installing firewalls
10. (2 points) What is the difference between RPO and RTO?
- A. RPO is about data loss; RTO is about downtime
 - B. RPO is about downtime; RTO is about data loss
 - C. They are the same
 - D. RPO applies to physical security; RTO applies to logical security
11. (2 points) Which of the following is a legal requirement that governs the protection of personal health information?

- A. GLBA
 - B. HIPAA
 - C. SOX
 - D. PCI DSS
12. (2 points) What is the principle of least privilege?
- A. Giving users maximum access
 - B. Giving users the minimum access necessary to perform their job
 - C. Giving users access based on seniority
 - D. Giving users access to all resources
13. (2 points) Which access control model uses security labels and clearances?
- A. Discretionary Access Control (DAC)
 - B. Mandatory Access Control (MAC)
 - C. Role-Based Access Control (RBAC)
 - D. Content-Dependent Access Control
14. (2 points) What is the primary weakness of symmetric cryptography?
- A. It is too slow
 - B. The key distribution problem
 - C. It uses too much processing power
 - D. It is not secure
15. (2 points) Which of the following is an example of a hash function?
- A. AES
 - B. RSA
 - C. SHA-256
 - D. ECC
16. (2 points) What does a digital signature provide?
- A. Only confidentiality
 - B. Authentication, integrity, and nonrepudiation
 - C. Only integrity
 - D. Only availability
17. (2 points) Which type of malware is self-replicating and does not require a host file to spread?
- A. Virus
 - B. Worm
 - C. Trojan
 - D. Ransomware
18. (2 points) What is a rootkit?

- A. A type of virus that infects boot sectors
 - B. Malware that modifies or replaces programs to hide compromise
 - C. A network-based attack tool
 - D. A type of encryption software
19. (2 points) Which of the following is a social engineering attack?
- A. SQL Injection
 - B. Buffer Overflow
 - C. Phishing
 - D. Cross-Site Scripting
20. (2 points) What is the first phase of a structured cyber attack?
- A. Weaponization
 - B. Delivery
 - C. Reconnaissance
 - D. Exploitation
21. (2 points) What is the role of a Security Operations Center (SOC)?
- A. To develop security policies
 - B. To monitor and respond to security incidents
 - C. To install network devices
 - D. To write software
22. (2 points) What does SIEM stand for?
- A. Security Information and Event Management
 - B. Security Infrastructure and Enterprise Management
 - C. System Information and Event Monitoring
 - D. Security Intelligence and Event Management
23. (2 points) What is the difference between a policy and a procedure?
- A. Policy is strategic; procedure is operational
 - B. Procedure is strategic; policy is operational
 - C. They are the same thing
 - D. Policy applies to IT; procedure applies to business
24. (2 points) What is system hardening?
- A. Changing default configurations to make a system more secure
 - B. Adding more features to a system
 - C. Installing more software
 - D. Removing all security features
25. (2 points) What is the difference between an IDS and an IPS?

- A. IDS is passive (detects); IPS is active (prevents)
 - B. IDS is active; IPS is passive
 - C. They are the same thing
 - D. IDS is for networks; IPS is for hosts
26. (2 points) Which type of detection compares traffic against known attack patterns?
- A. Anomaly-based detection
 - B. Signature-based detection
 - C. Behavioral detection
 - D. Statistical detection
27. (2 points) What is a false positive in monitoring?
- A. An alert triggered for benign activity
 - B. A real attack that was missed
 - C. A configuration error
 - D. A successful attack
28. (2 points) What is the primary purpose of a security audit?
- A. To install new security software
 - B. To provide independent assurance that controls are working
 - C. To train employees on security awareness
 - D. To develop new security policies
29. (2 points) Which of the following is a benefit of cloud computing?
- A. No need to maintain a data center
 - B. Greater difficulty in keeping data secure
 - C. Increased data leakage
 - D. Need for constant network access
30. (2 points) What is the difference between vulnerability testing and penetration testing?
- A. Vulnerability testing identifies weaknesses; penetration testing exploits them
 - B. Penetration testing identifies weaknesses; vulnerability testing exploits them
 - C. They are the same thing
 - D. Vulnerability testing is for networks; penetration testing is for applications

Section B: True/False (20 points)

31. (2 points) The human factor is considered the weakest link in information security.
- A. True
 - B. False
32. (2 points) A law is a legislative piece voted on by the people for the people.

- A. True
 - B. False
33. (2 points) Spear phishing is a generalized, untargeted phishing attack.
- A. True
 - B. False
34. (2 points) Qualitative risk assessment is faster but more subjective than quantitative assessment.
- A. True
 - B. False
35. (2 points) A cold site is the fastest and most expensive disaster recovery option.
- A. True
 - B. False
36. (2 points) Kerberos provides mutual authentication between user and server.
- A. True
 - B. False
37. (2 points) RSA is a symmetric encryption algorithm.
- A. True
 - B. False
38. (2 points) Defense-in-depth means using only one security control.
- A. True
 - B. False
39. (2 points) Log files are not important for accountability.
- A. True
 - B. False
40. (2 points) A DMZ is a buffer zone between trusted and untrusted networks.
- A. True
 - B. False

Section C: Short Answer (70 points)

41. (10 points) Explain the CIA Triad and why each component is essential for information security.

-
42. (10 points) Describe the five steps of the risk management process.
43. (10 points) What is the difference between authentication and authorization? Provide an example of each.
44. (10 points) Compare symmetric and asymmetric cryptography. List one strength and one weakness of each.
45. (10 points) Explain the difference between a virus, a worm, and a Trojan horse. How does each spread?
46. (10 points) Describe the incident response lifecycle (NIST SP 800-61) and explain the purpose of each phase.
47. (10 points) What is defense-in-depth? List at least four layers of defense and explain how they work together.

Answer Key — Practice Test 1

Section A: Multiple Choice

1. **B** – Protection of information and its critical elements
2. **C** – Availability
3. **C** – Management Domain
4. **B** – Kevin Ashton
5. **B** – To reduce risk and guide security decisions
6. **B** – Impact
7. **B** – Qualitative risk assessment
8. **A** – $SLE = AV \times EF$
9. **B** – Identifying critical business functions and their recovery requirements
10. **A** – RPO is about data loss; RTO is about downtime
11. **B** – HIPAA
12. **B** – Giving users the minimum access necessary to perform their job
13. **B** – Mandatory Access Control (MAC)
14. **B** – The key distribution problem
15. **C** – SHA-256
16. **B** – Authentication, integrity, and nonrepudiation
17. **B** – Worm
18. **B** – Malware that modifies or replaces programs to hide compromise
19. **C** – Phishing
20. **C** – Reconnaissance
21. **B** – To monitor and respond to security incidents
22. **A** – Security Information and Event Management
23. **A** – Policy is strategic; procedure is operational
24. **A** – Changing default configurations to make a system more secure
25. **A** – IDS is passive (detects); IPS is active (prevents)
26. **B** – Signature-based detection
27. **A** – An alert triggered for benign activity
28. **B** – To provide independent assurance that controls are working
29. **A** – No need to maintain a data center
30. **A** – Vulnerability testing identifies weaknesses; penetration testing exploits them

Section B: True/False

1. **True** – The human factor is the weakest link
2. **True** – A law is legislative
3. **False** – Spear phishing is highly targeted
4. **True** – Qualitative is faster but more subjective
5. **False** – A cold site is the slowest and least expensive
6. **True** – Kerberos provides mutual authentication
7. **False** – RSA is asymmetric
8. **False** – Defense-in-depth uses multiple layers

9. **False** – Log files are essential for accountability
10. **True** – A DMZ is a buffer zone

Section C: Short Answer Grading Criteria

1. CIA Triad (10 points)

- **Confidentiality:** Ensuring only authorized users access information (encryption, access controls)
- **Integrity:** Maintaining accuracy and completeness of data (hash verification, digital signatures)
- **Availability:** Ensuring authorized access when needed (redundant systems, backups)

2. Risk Management Process (10 points)

- (a) Identify Risks
- (b) Assess and Prioritize Risks
- (c) Plan Risk Response
- (d) Implement Risk Response
- (e) Monitor and Control Risk Response

3. Authentication vs. Authorization (10 points)

- **Authentication:** Proving identity (e.g., entering a password)
- **Authorization:** Determining what you can do after identity is verified (e.g., accessing specific files)

4. Symmetric vs. Asymmetric Cryptography (10 points)

- **Symmetric:** Same key; fast but key distribution problem
- **Asymmetric:** Public/private keys; solves key distribution but slower

5. Virus, Worm, Trojan (10 points)

- **Virus:** Requires user action, attaches to host, spreads
- **Worm:** Self-replicating, no host, spreads via network
- **Trojan:** Disguised as legitimate, does not self-replicate

6. Incident Response Lifecycle (10 points)

- Preparation: Planning and training
- Detection & Analysis: Identifying and analyzing incidents
- Containment: Limiting scope
- Eradication: Removing root cause
- Recovery: Restoring systems
- Post-Incident: Lessons learned

7. Defense-in-Depth (10 points)

- Multiple layered defenses (physical, network, host, application, data, user)
- Each layer addresses different threats; if one fails, others protect